Structurer le corpus de scénarios LANCE avant le gel

Grille dérivée, edge cases déployables, sets et séquençage

Projet LANCE

Dernière révision : 2026-10-12 23:05 (Europe/Brussels, UTC+02:00)
Statut : propositions relues — aucun résultat expérimental nouveau

Résumé

Le corpus actuel compte 29 scénarios et 288 vulnérabilités attendues, dont 75 % à signature : il est adapté au développement, pas à l'évaluation comparative visée à AsiaCCS 2027. Ce rapport décide comment le structurer avant tout gel. Il retient une grille d'étiquetage *dérivée* des vérités terrain existantes, stockée dans un index annexe régénérable sans modifier le catalogue ni les vérités terrain ; quatre edge cases retenus — EC1 et EC2 déployables, EC3 et EC4 à valider en exécution réelle (variation de surface, bruit et leurres, chaînage cassable, autorisation presque valide) —, deux autres explicitement différés après la soumission ; un set pilote de calibration (S1, S14, S15, S1h) et un set campagne à split par famille dimensionné par la variance du pilote ; enfin un séquençage en trois horizons avec critères d'arrêt à la décision du 2026-11-16. Les propositions ont été soumises à deux contre-revues (méthodologie, faisabilité) dont les corrections sont intégrées.

Table des matières

1 Objectif, périmètre et méthode **1**

2 Grille d'étiquetage retenue : dériver, ne pas réécrire **2**

3 Edge cases retenus, par ordre de déployabilité **2**

4 Sets tirés de la grille **3**

5 Séquençage en trois horizons **3**

6 Ce qu'on ne fait pas avant le 11 décembre **4**

7 Limites et points non résolus **4**

8 Conclusion **5**

1 Objectif, périmètre et méthode

Ce document répond à la question : que faut-il structurer, compléter ou geler dans le corpus de scénarios — et dans quel ordre — pour que la comparaison entre la politique à règles D1 (`rules`) et la politique à modèle A1 (`llm`) soit recevable à AsiaCCS 2027 (soumission le 2026-12-11, décision intermédiaire le 2026-11-16) ? Il prolonge l'audit de couverture du dossier d'objectifs

(`objectifs/asiaccs-2027/audit-couverture.md` : 215 failles sur 288 à signature, strate logique réduite au seul S15, axes variation/bruit/protocole non encodés, chaînage confondu avec la taille des scénarios) et la proposition de recentrage de ce dossier (`proposition-conditions.tex`).

Méthode : trois propositions parallèles (structuration, edge cases, séquençage), deux contre-revues indépendantes (méthodologie : contamination et étiquetage arrangeant ; faisabilité : effort réel sur l'infrastructure Ansible/Proxmox et délai), puis synthèse. Les corrections des relecteurs sont intégrées au corps du texte. Statut : propositions — aucun run, aucun déploiement et aucune génération n'ont été exécutés pour ce rapport ; les efforts (en jours-personne, j-h) sont des estimations à confirmer. Définitions minimales : une *famille* est un mécanisme de faille (pack) ; une *instance* est une variante déployée d'une famille ; un *edge case* est une situation conçue pour séparer les comportements (réviser, s'abstenir, distinguer), pas seulement les scores.

2 Grille d'étiquetage retenue : dériver, ne pas réécrire

Premier constat vérifié : le catalogue (`benchmarks/catalog.yaml`, chargé par `src/benchmark/catalog.py`) impose un schéma strict de clés (`id`, `label`, `split`, `profile`) et rejette toute clé inconnue. Ajouter des champs d'étiquetage au catalogue casserait donc son chargement. Décision : **catalogue et vérités terrain inchangés** ; la grille est une vue *calculée*.

Les champs existent déjà dans les vérités terrain : par faille (`category`, `hop_depth`, `severity`, `template_key`, `security_profile`), par scénario (`difficulty`, `controls`, `attack_paths`, `scoring`). Le recalcul sur les 31 fichiers (29 scénarios, 2 durcis) confirme l'audit : 70 misconfigurations, 54 expositions de données, 50 absences d'authentification, 41 identifiants par défaut ; profondeur de saut 0 : 166 failles, 1 : 67, 2 : 49, 3 : 6 — le chaînage est porté par les gros scénarios de développement (S11–S13), d'où la confusion taille/profondeur à découpler.

La grille dérivée comporte cinq axes, jamais saisis à la main :

— **Type** : `signature` ou `logique`, déduit de la catégorie (logique = autorisation, tenant, JWT, IDOR ; aujourd'hui S15 seul).
— **Chaînage** : profondeur de saut (`hop_depth`), utilisée comme axe propre, découplée de la taille du scénario dans l'analyse.
— **Surface** : `base`, `rotate_ips`, `rename_hosts` — lu depuis le manifeste d'altération appliqué à l'instance, pas depuis la vérité terrain.
— **Bruit** : `none`, `decoys`, `near_miss`, `noise`, `evidence_degradee` — même source (manifeste d'altération).
— **Protocole** : `connu` ou `inconnu`, explicite ; aujourd'hui non encodé, valeur par défaut `connu` (limite documentée, section 7).

Stockage : un index annexe généré et versionné (par exemple `benchmarks/labels/derived_index.json`), clé (scénario, faille), régénérable depuis les vérités terrain et les manifestes d'altération, avec empreintes des sources. L'unité d'analyse réutilise celle, déjà opérationnelle, de la campagne (`family_id` / `instance_id` / `trial_id`, agrégation par famille dans `src/benchmark/policy_campaign.py`). Effort estimé : script de dérivation et tests de non-régression du chargement du catalogue, 2 à 3 j-h ; validation croisée contre l'audit de couverture, 0,5 j-h.

3 Edge cases retenus, par ordre de déployabilité

Six edge cases étaient candidats (intermittence, bannière mensongère, identifiants presque valides, faille non confirmable, hôte incohérent, leurre plausible). Les contre-revues ont imposé un filtre décisif : une altération seulement prévue (`PREVIEW_ONLY`) n'est pas déployable — le garde-fou d'exécution réelle (`manual_execution.py`) bloque ces altérations, et un résultat en aperçu ne vaut pas preuve. Le tableau 1 retient quatre cas, dans l'ordre.

Cas	Génération	Vérification exigée
EC1 Variation de surface	Altérations déployables `rotate_ips`, `rename_hosts` sur une instance d'une famille	Vérité terrain inchangée hors adresse/nom ; chargement et déploiement réels OK ; même scoring
EC2 Bruit et leurres	`add_decoys`, `near_miss_controls`, `add_noise`, `degrade_evidence` ; instance sœur de EC1	Failles constantes en nombre et catégorie ; aucun leurre compté comme faille (contrôle négatif)
EC3 Chaînage cassable	Pack `f20` (pivots SSH/HTTP, profondeur 0–3) : rompre un seul maillon en gardant la profondeur cible	Chemins d'attaque de la vérité terrain cohérents, profondeur recalculée, aucun chemin alternatif résiduel
EC4 Autorisation presque valide	Pack `f11` et S15 (simulateur déterministe porteur/IDOR/JWT) : variantes à portée presque suffisante, tenant voisin	Réponse déterministe du simulateur ; axe type = logique ; la classe logique dépasse enfin $n = 1$

Table 1 – Edge cases retenus avant la soumission, par déployabilité décroissante. Efforts estimés : EC1 et EC2, 1 à 2 j-h chacun (existant, surtout tests) ; EC3, 2 à 3 j-h ; EC4, 2 à 4 j-h. Vérification transverse : chaque cas doit passer le garde-fou d'exécution réelle, pas seulement l'aperçu.

Différés après la soumission : **EC5** (défaillance temporelle : `rate_limit`, `startup_delay`, `service_availability` sont écrits en topologie sans être déployés) et **EC6** (protocole inconnu : exige un nouveau mode du simulateur HTTP unique, déployé par Ansible sur conteneurs LXC — le chantier le plus lourd, pour l'axe le moins couvert). Ils sont documentés comme limites, non comblés ; seul un essai borné de EC5 est admissible si le pilote finit tôt.

4 Sets tirés de la grille

Pilote (calibration, aucune puissance revendiquée). S1 (routine), S14 (faible prévalence), S15 (logique, unique), S1h (durci existant, zéro faille) qui *remplace* le contrôle sain fictif encore présent dans le manifeste exemple (`ground_truth:null`) : un contrôle sans vérité terrain ne doit jamais être agrégé. Format hérité : 12 paires, 24 runs, ordre à randomiser avant gel (le manifeste actuel est non gelé, configuration vide, contrôles en attente, ordre alterné non randomisé). Effort : gel du manifeste et randomisation, 1 j-h ; exécution et dépouillement, 2 à 3 j-h.

Campagne (après la décision du 2026-11-16 seulement). Split **par famille**, jamais par instance, pour éviter la fuite entre variantes d'une même famille ; instances procédurales générées par famille via EC1 et EC2 (plus EC3/EC4 sur les familles concernées), car 29 scénarios seuls ne donnent pas la puissance sur les hypothèses H0–H3. Rappel des hypothèses testées (proposition compagne) : H0 aucun écart au-delà de δ ; H1 écart conditionnel (nouveauté, logique, protocole inconnu) ; H2 résilience différentielle sous bruit ; H3 coût de l'avantage. Taille fixée par calcul de puissance sur la variance du pilote, jamais à l'avance. Critère pré-enregistré : borne inférieure de l'intervalle de confiance apparié à 95 % supérieure à δ (valeur de travail 5 points) après correction de Holm ; quatre contrôles négatifs invalidant le lot entier si l'un échoue — dont les durcis S1h et S4h (second scénario durci, ICS/SCADA, zéro faille) : toute « faille » rapportée sur un durci invalide le lot. Effort : génération et contrôles, 5 à 8 j-h, exécution selon la taille calculée.

5 Séquençage en trois horizons

— **Horizon 1 — jusqu'au 2026-11-16 (décision).** Grille dérivée et index annexe ; EC1 et EC2 activés sur le pilote, EC3 et EC4 prototypés ; manifeste pilote gelé et 12 paires exécutées. Effort 8

à 12 j-h. Décision : *GO* si la borne pilote est compatible avec δ et les quatre contrôles tiennent ; *REPOSITIONNÉ* si l'effet est réel mais sous δ, ou porté par le seul axe signature (contribution recentrée sur le benchmark) ; *NO-GO* si un contrôle tombe ou si l'effet disparaît après déconfusion taille/profondeur.

— **Horizon 2 — 2026-11-17 au 2026-12-11 (soumission).** Uniquement si GO ou REPOSITIONNÉ : campagne à split par famille, rédaction des 12 pages ACM, paquet Open Science, anonymisation double aveugle, ORCID. Gel des résultats au plus tard 7 à 10 jours avant le dépôt ; aucun nouvel edge case après ce gel. Effort 10 à 15 j-h hors temps machine.

— **Horizon 3 — après le 2026-12-11.** EC5 et EC6, poursuite conditionnelle des phases 2 et 5. Critère d'entrée : soumission déposée ; critère d'arrêt propre : fournisseur réel testé en exécution, ou abandon documenté. Non budgété avant le dépôt.

La figure 1 résume ce séquençage.

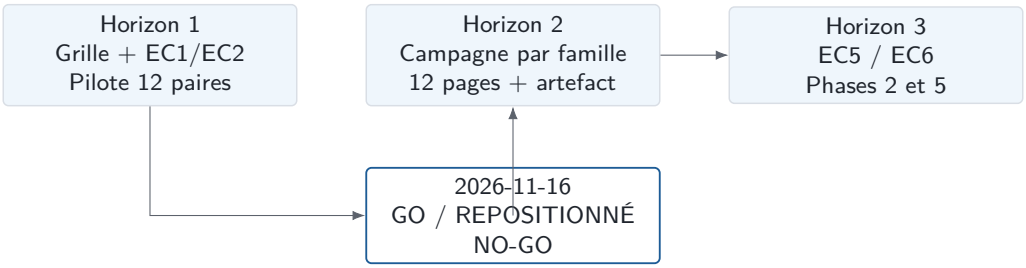


Figure 1 – Séquençage proposé en trois horizons, articulé sur la décision du 2026-11-16. Calendrier de travail, pas un résultat.

6 Ce qu'on ne fait pas avant le 11 décembre

Six exclusions, chacune motivée par la validité ou le calendrier : (i) aucun fournisseur (*provider*) pour les altérations `PREVIEW_ONLY` (`rotate_ports`, segmentation, disponibilité, délais, limitation, impairment) — effort incompatible avec cinq semaines avant décision, preuve en aperçu irrecevable ; (ii) aucun nouveau mode « protocole inconnu » du simulateur ; (iii) aucune modification du schéma du catalogue ni des vérités terrain pour y encoder surface, bruit ou protocole — ces axes vivent dans le manifeste d'altération et l'index dérivé ; (iv) aucune extension du pilote au-delà de 12 paires ni campagne anticipée — sans variance pilote, le calcul de puissance est fictif ; (v) aucun bonus hors chemin critique (phases 2/5, durcissements nouveaux au-delà de S1h/S4h, refonte de l'agrégation qui fonctionne) ; (vi) aucun usage du contrôle sain fictif comme résultat.

7 Limites et points non résolus

Les altérations `PREVIEW_ONLY` restent bloquées en exécution réelle, sans fournisseur livré avant le 2026-12-11. Protocole inconnu, variation de surface et bruit ne sont pas encodés dans les vérités terrain ; seuls surface et bruit sont dérivables du manifeste d'altération, l'axe protocole reste une limite documentée. La taille de campagne n'est pas fixable avant la variance du pilote. Le manifeste pilote reste à geler (configuration vide, contrôles en attente, ordre à randomiser). EC4 doit démontrer en exécution réelle que la classe logique dépasse $n = 1$; sinon la condition logique reste à un seul représentant. Enfin, la déconfusion taille/profondeur par l'index dérivé n'est pas encore validée sur le pilote.

8 Conclusion

Le corpus n'a pas besoin d'être reconstruit, mais lu à travers une grille : étiqueter en dérivant, compléter par quatre edge cases déployables dans l'ordre, tirer les sets de la grille, et geler seulement à la veille de mesurer. La prochaine action est le script d'index dérivé et le gel du manifeste pilote sur S1, S14, S15, S1h — pas un scénario de plus.